

TỔNG CỤC II

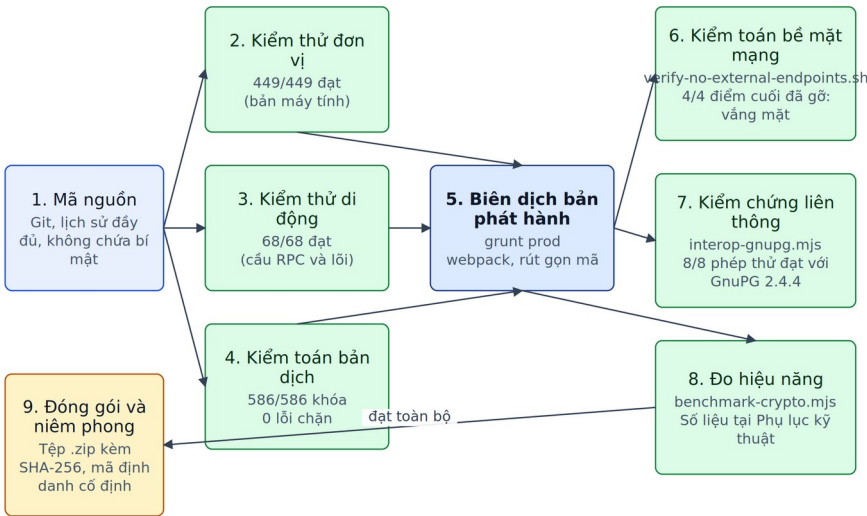
HỌC VIỆN KHOA HỌC QUÂN SỰ

PHỤ LỤC KỸ THUẬT

PHỤ LỤC KỸ THUẬT

Toàn văn kết quả kiểm thử, đo đạc và kiểm toán — kèm hướng dẫn tái lập

Quy trình xây dựng và kiểm chứng một bản phát hành



Các bước 6, 7 và 8 đều là kịch bản chạy được, kết quả kèm trong hồ sơ. Người thẩm định chạy lại được trên chính bản phát hành để tự kiểm chứng, không phải tin vào lời khẳng định.

Thuộc hồ sơ

Phiên bản sản phẩm

Ngày thực hiện đo

Môi trường đo

Sáng kiến Secure Mail

Secure Mail v0.3.0

08/9/2026

AMD EPYC 4 nhân, 7,8 GB RAM,

Linux

Hà Nội, ngày tháng năm 2026

MỤC LỤC

...

(Mở tệp trong Word và nhấn Ctrl+A rồi F9 để cập nhật mục lục và số trang)

MỤC ĐÍCH CỦA PHỤ LỤC

Phụ lục này chứa **toàn văn kết quả** của mọi phép đo và phép thử được viện dẫn trong Bản thuyết minh, cùng **lệnh chính xác** để chạy lại từng phép.

Mục đích không phải là trưng bày số liệu mà là để Hội đồng, hoặc bất kỳ ai được giao thẩm định, **tự kiểm chứng thay vì phải tin tác giả**. Trong an toàn thông tin, một khẳng định không kiểm chứng được thì không có giá trị.

Toàn bộ kết quả dưới đây được sinh ra trong cùng một lần chạy, ngày 08/9/2026, trên bản phát hành secure-mail-v0.3.0-hardened.

A. KIỂM THỬ VÀ KIỂM TOÁN

A.1. Môi trường đo

Bảng A.1. Môi trường thực hiện các phép đo

Thành phần	Giá trị
Bộ xử lý	AMD EPYC Processor (with IBPB), 4 nhân
Bộ nhớ	7,8 GB
Hệ điều hành	Linux 6.8.0-139-generic
Node.js	v22.23.1 (đo hiệu năng, kiểm thử) và v24.15.0 (biên dịch bản phát hành)
Trình duyệt dùng để chụp và kiểm thử giao diện	Chrome for Testing 149.0.7827.22
Thư viện mật mã	OpenPGP.js 5.11.3 — đúng phiên bản mà bản phát hành đóng gói
Phần mềm đối chứng liên thông	GnuPG 2.4.4, libgcrypt 1.10.3

Số liệu hiệu năng đặc trưng cho **cách hiện thực của phần mềm**, không đặc trưng cho phần cứng của một triển khai cụ thể. Cấu hình máy được ghi lại để người đọc quy chiếu.

A.2. Kiểm thử đơn vị bản máy tính

Lệnh chạy lại:

```
cd
npx jest --selectProjects unit
```

mailvelope

Kết quả:

Test Suites:	22	passed,	22	total
Tests:		449	passed,	449
Snapshots:			0	total
Time:			31.977	s
Ran all test suites.				

Ba phép thử trong bộ này đã thất bại trước khi hoàn thiện hồ sơ, do vẫn kiểm tra tên và địa chỉ của sản phẩm gốc sau khi đổi nhận diện sản phẩm:

- `ActionMenuWrapper` › should render help link with correct href — vẫn mong đợi `https://www.mailvelope.com/faq`
- `ActionMenuWrapper` › should render action menu header with logo — vẫn mong đợi `img/Mailvelope/logo.svg`
- `KeyServer` › should render learn more links — vẫn đếm liên kết tới `mailvelope.com/faq`

Đây là nợ kỹ thuật thực sự: một bộ kiểm thử không chạy trọn vẹn thì mất giá trị bảo đảm, vì lỗi mới sẽ lẫn vào những lỗi đã biết. Cả ba đã được sửa để kiểm tra đúng tài nguyên của Secure Mail.

A.3. Kiểm thử bản di động**Lệnh chạy lại:**

<code>cd</code>	<code>mobile</code>
<code>npx jest</code>	

Kết quả:

Test Suites:	10	passed,	10	total
Tests:		68	passed,	68
Snapshots:			0	total
Time:			36.65	s
Ran all test suites in 3 projects.				

Nội dung 68 phép thử bao gồm: hợp đồng cầu RPC có kiểu (định dạng gói tin, timeout, lan truyền lỗi sập), các lớp đệm thay thế API của Chrome, các bộ xử lý chùm khóa, mã hóa, sao lưu và tùy chọn, **phép thử đối chứng (golden)** so khớp kết quả với dữ liệu chuẩn sinh từ bản máy tính, và **phép thử liên thông** giải mã bằng thư viện độc lập.

A.3.1. Kiểm chứng bản máy tính không bị thay đổi

Ràng buộc "không được sửa bản máy tính đang chạy ổn định trong khi phát triển bản di động" được biến thành một phép kiểm tra tự động.

Lệnh chạy lại:

```
cd
./scripts/verify-desktop-untouched.sh
```

mobile

Kết quả:

```
OK: mailvelope/ pristine at e85da308 (161 extension files verified)
```

Kịch bản kiểm tra ba điều: cây làm việc của kho bản máy tính sạch, HEAD trùng với mốc đã ghim, và 161 tệp trong build/chrome/ khớp mã băm SHA-256 của bản phát hành.

Trong quá trình xây dựng hồ sơ này, kịch bản đã **từ chối** ngay khi bản máy tính được sửa để gỡ bỏ thư viện đo lường và cơ chế kiểm tra giấy phép — đúng như thiết kế. Mốc ghim chỉ được cập nhật cho những thay đổi đã được chủ động quyết định, và mỗi lần cập nhật đều được ghi lại trong chính kịch bản.

A.3.2. Kiểm thử lỗi mật mã trong Chromium — engine của Android System WebView

Đây là bằng chứng gần thiết bị Android nhất có thể thu được mà không cần máy thật. **WebView trên Android là Chromium**; kiến trúc trình bày tại Bản thuyết minh (mục 3, phần b, tiểu mục 6) nạp lỗi mật mã vào chính WebView đó. Phép thử này nạp **đúng gói bundle mà ứng dụng Android sẽ nạp** vào Chromium Chrome/149.0.7827.22 và chạy trọn vòng đời qua hợp đồng RPC.

Lệnh chạy lại:

```
cd
npm run
node test/webview-chromium.mjs
```

mobile
build:core

Gói bundle được phục vụ qua HTTP để **chính sách CSP của trang có hiệu lực đúng như trong ứng dụng** (default-src 'none'; script-src 'self'; connect-src 'none'); nạp qua file:// sẽ nói lỏng CSP và làm phép thử mất giá trị.

Bảng A.2. Kết quả chạy lỗi mật mã trong Chromium

Phép thử	Chi tiết	Kết quả
Bundle nạp được trong Chromium	window.SecureMailCore hiện diện sau khi trang tải xong	PASS
Năng lực nền tảng đầy đủ	crypto.subtle, getRandomValues, TextEncoder, ReadableStream đều có	PASS
Khởi tạo lỗi mật mã trong WebView	createCore trả về API sẵn sàng	PASS
Sinh cặp khóa RSA-4096 trong WebView	hoàn tất sau 2327 ms	PASS
Sinh cặp khóa thứ hai	hoàn tất sau 2342 ms	PASS
Liệt kê chùm khóa	2 khóa trong chùm khóa	PASS
Đọc chi tiết khóa	dấu vân tay 1D91CF0F823843AC...	PASS
Xuất khóa công khai	khối BEGIN PGP PUBLIC KEY BLOCK hợp lệ	PASS
Mã hóa kèm ký số	209 ms, khối bản mã 2629 byte	PASS
Giải mã và xác minh chữ ký	549 ms, bản rõ đúng từng ký tự, tiếng Việt nguyên vẹn	PASS
Chữ ký được xác minh hợp lệ	1 chữ ký hợp lệ	PASS
Khóa sinh trong WebView đọc được bằng thư viện độc lập	OpenPGP.js chạy trong Node phân tích đúng khóa và khớp dấu vân tay	PASS
Bản mã sinh trong WebView là OpenPGP chuẩn	thư viện độc lập phân tích được khối và thấy đúng 2 khóa người nhận	PASS
Khóa lại ứng dụng	app.lock trả về thành công	PASS
Sau khi khóa vẫn giải mã được khi cung cấp lại cụm mật khẩu	bộ nhớ đệm bị xóa, lỗi yêu cầu lại cụm mật khẩu qua bridge	PASS
Đọc tùy chọn	prefs.get trả về cấu hình	PASS
Tổng		16/16 ĐẠT

Bảng A.3. Thời gian đo được trong Chromium

Thao tác	Thời gian
Sinh cặp khóa RSA-4096, lần 1	2,327 ms
Sinh cặp khóa RSA-4096, lần 2	2,342 ms
Mã hóa kèm ký số cho 2 người nhận	209 ms
Giải mã kèm xác minh chữ ký	549 ms

Phép thử này chứng minh điều gì. Lỗi mật mã của bản di động — bao gồm chòm khóa, sinh khóa, mã hóa, ký, giải mã, xác minh, khóa lại và tùy chọn — hoạt động đúng trên engine mà Android sử dụng, với chính gói bundle sẽ được đóng vào ứng dụng. Hai phép thử liên thông trong bảng dùng một thư viện OpenPGP **độc lập chạy ngoài WebView** làm trọng tài, nên kết quả không tự quy chiếu.

Phép thử này KHÔNG chứng minh điều gì. Nó không phủ tâng giao diện React Native, Android Keystore, quyền truy cập tệp, hành vi khi hệ điều hành thu hồi bộ nhớ, và khác biệt giữa các phiên bản Android. Những phần đó nằm trong ma trận kiểm thử trên thiết bị tại mục G và **chưa được thực hiện** — hồ sơ không khẳng định chúng.

Ba khiếm khuyết mà phép thử này phát hiện trong quá trình xây dựng, đều đã được xử lý và ghi lại vì chúng cho thấy phép thử có tác dụng thật: hợp đồng của bộ cung cấp cụm mật khẩu trả về {password, cache} chứ không phải chuỗi — trả sai kiểu khiến vòng lặp mở khóa quay vô hạn thay vì báo lỗi; keyring.exportKeys nhận tham số fingerprints và trả {armored}; và bản rõ trả về là chuỗi byte UTF-8 kèm xuống dòng CRLF theo RFC 4880, nên một phép so sánh chỉ áp dụng một trong hai phép biến đổi sẽ báo sai.

A.4. Kiểm toán bản dịch tiếng Việt

Lệnh chạy lại:

```
cd mailvelope
node scripts/verify-translation.mjs
```

Kết quả:

```
English      keys      :      586
Vietnamese   keys      :      586
Coverage     :      100%
Missing      :      0
Placeholder          errors:      0
Markup       errors      :      0
Untranslated      :      2
Glossary          deviations:      0

Other locales: {"ar":531,"de":579,"en":586,"es":489,"fr":534,"he":507,
"id":531,"ja":528,"km":512,"lt":517,"my":512,"pt_BR":531,"ru":530,
"tr":533,"uk":534,"vi":586}
```


Hai giá trị được báo là "chưa dịch" là Gmail API và Copyright © Tracy Tran — đều là danh từ riêng, giữ nguyên là đúng. Không có sai lệch thuật ngữ nào.

A.4.1. Sáu lỗi do kiểm toán phát hiện và đã sửa

Ghi lại đầy đủ, vì việc một quy trình tự tìm ra lỗi là bằng chứng quy trình đó hoạt động.

Bảng A.4. Các lỗi bản dịch được phát hiện và cách xử lý

Mã chuỗi	Lỗi	Mức độ	Xử lý
onboarding_success_created_key_text	Bản dịch bỏ mất câu yêu cầu gửi khóa công khai và dấu vân tay cho quản trị viên qua kênh đã xác thực — tức bỏ mất chính bước bảo đảm tính xác thực của khóa	Ảnh hưởng an toàn	Dịch lại đầy đủ cả ba câu
recovery_sheet_trusted_contacts	Bản dịch bỏ mất khuyến cáo phải tự xác minh danh tính đối với liên hệ dùng nhà cung cấp thư khác	Ảnh hưởng an toàn	Dịch lại đầy đủ
recovery_sheet_key_server	Mất hai trong ba ô thay thế \$1, làm thông báo hiển thị thiếu giá trị động	Lỗi chức năng	Khôi phục đủ ba ô
7 chuỗi khác nhau	Thuật ngữ "private key" được dịch không nhất quán: lần giữa "khóa bí mật" và "khóa riêng tư"	Ảnh hưởng nhận thức	Thống nhất về "khóa riêng tư"
onboarding_setup_alert	Từ "fingerprint" để nguyên tiếng Anh, không nhất quán với bộ thuật ngữ	Chất lượng	"dấu vân tay (fingerprint)"
decrypt_digital_signature_sender_mismatch_tooltip	Diễn đạt "khóa đã ký" không nói rõ là khóa công khai của người ký	Chất lượng	Diễn đạt lại chính xác

Lý do chọn "khóa riêng tư" thay vì "khóa bí mật": tránh gây liên tưởng nhầm tới "bí mật nhà nước", đồng thời nhấn vào tính sở hữu cá nhân của khóa — người dùng

phải hiểu rằng đây là thứ **của riêng mình** và không bao giờ được giao cho ai, kể cả quản trị viên.

A.5. Kiểm toán bề mặt mạng của gói phát hành

Lệnh chạy lại:

```
cd mailvelope \
./scripts/verify-no-external-endpoints.sh
releases/secure-mail-v0.3.0-hardened/extension
```

Kết quả (toàn văn):

```
Secure Mail - network-surface audit of
releases/secure-mail-v0.3.0-hardened/extension
=====
[1] Forbidden endpoints (must be absent)
-----
PASS cleaninsights 0 occurrences
PASS metrics.cleaninsights.org 0 occurrences
PASS license.mailvelope.com 0 occurrences
PASS mailvelope.com/google-workspace 0 occurrences
[2] Network call sites in the source (complete list)
-----
src/controller/app.controller.js
src/lib/svg-file-parser.js
src/modules/gmail.js
src/modules/mveloKeyServer.js
src/modules/openpgpKeyServer.js
src/modules/wkdLocate.js
Resolved hosts and their status:
accounts.google.com Gmail sign-in ENABLED (feature in
use)
oauth2.googleapis.com OAuth token exchange ENABLED (feature in
use)
www.googleapis.com Gmail API + userinfo ENABLED (feature in
use)
keys.mailvelope.com public key server DISABLED by default
keys.openpgp.org public key server DISABLED by default
<recipient domain> WKD key lookup by domain DISABLED by default
chrome-extension://... bundled SVG assets local only, never
remote
=====
RESULT: PASS - no removed endpoint is present.
```

A.5.1. Ghi chú về phương pháp kiểm toán

Kịch bản cố ý **không** liệt kê mọi chuỗi giống URL tìm thấy trong gói đã biên dịch. Cách làm đó cho ra hàng trăm kết quả sai: các thư viện phía giao diện nhúng liên

kết tài liệu trong thông báo lỗi của chúng, và những liên kết đó không bao giờ được truy cập.

Bề mặt mạng thật của một chương trình là **tập hợp các điểm phát sinh yêu cầu mạng**. Kịch bản liệt kê đúng tập hợp đó bằng cách tìm mọi lời gọi fetch, XMLHttpRequest, WebSocket và sendBeacon trong mã nguồn. Kết quả là **sáu tệp**, và trong đó `svg-file-parser.js` chỉ nạp tệp đồ họa đóng gói sẵn qua `chrome.runtime.getURL()` — luôn là địa chỉ nội bộ của tiện ích, không bao giờ ra mạng.

A.5.2. Đối chiếu trước và sau

Bảng A.5. Số lần xuất hiện của các điểm cuối bên thứ ba trong gói đã biên dịch

Chuỗi tìm kiếm	Bản trước cải tạo	Bản v0.3.0
<code>cleaninsights</code>	9	0
<code>license.mailvelope.com</code>	1	0
<code>mailvelope.com/google-workspace</code>	1	0
<code>keys.mailvelope.com</code>	2	2 — mã còn, chức năng tắt mặc định

Dòng cuối được ghi lại **đúng như thực tế** thay vì làm tròn thành số không: mã tra cứu máy chủ khóa vẫn còn trong sản phẩm, chỉ là tắt mặc định. Giữ lại là có chủ đích — nếu về sau đơn vị tự vận hành một máy chủ khóa nội bộ thì bật lại được. Hồ sơ phân biệt rõ hai mức bảo đảm này thay vì gộp chung.

A.6. Kiểm chứng liên thông với GnuPG

Đây là phép thử quan trọng nhất về mặt bảo đảm lâu dài: nó chứng minh bản mã của Secure Mail là **OpenPGP chuẩn**, đọc được bằng phần mềm khác, trên nền tảng khác, kể cả khi Secure Mail không còn được dùng. Nói cách khác, dữ liệu của đơn vị không bị khóa vào một sản phẩm.

Lệnh chạy lại:

```
cd mailvelope
node scripts/interop-gnupg.mjs
```

Kịch bản sinh một cặp khóa RSA-4096 bằng thư viện của Secure Mail và một cặp khóa RSA-4096 bằng GnuPG trong một thư mục khóa tạm, rồi trao đổi thư thật theo cả hai chiều. Nội dung thử là văn bản tiếng Việt có dấu, nên phép thử đồng thời xác nhận đường xử lý UTF-8 không bị hỏng khi đi qua một phần mềm khác.

Kết quả (toàn văn):

```

gpg                (GnuPG)                2.4.4                /                openpgp                5.11.3

gpg:                key                B1A8FA76FC3F0D74:                public                key
                  "Secure Mail User <securemail@donvi.test>" imported
gpg:                Total                number                processed:                1
gpg:                imported:                1

PASS                Key import (Secure Mail -> GnuPG)
                  GnuPG accepted the RSA-4096 public key produced by OpenPGP.js
PASS                Key import (GnuPG -> Secure Mail)
                  OpenPGP.js parsed the GnuPG key, fingerprint D35D0816317DC81A...
PASS                A. Confidentiality (Secure Mail -> GnuPG)
                  GnuPG recovered the plaintext byte-for-byte, diacritics intact
PASS                A. Authenticity (Secure Mail -> GnuPG)
                  GnuPG reported GOODSIG for the Secure Mail signature
PASS                B. Confidentiality (GnuPG -> Secure Mail)
                  OpenPGP.js recovered the plaintext byte-for-byte, diacritics
intact
PASS                B. Authenticity (GnuPG -> Secure Mail)
                  OpenPGP.js verified the GnuPG signature against the imported key
PASS                C. Detached signature (Secure Mail -> GnuPG)
                  GnuPG verified a detached signature produced by Secure Mail
PASS                D. Integrity (tampered ciphertext)
                  A single flipped character in the ciphertext is rejected,
                  not silently mis-decrypted

ALL PASS

```

A.6.1. Ý nghĩa của từng phép thử

- **Nhập khóa hai chiều** — định dạng khóa công khai tương thích, đơn vị trao đổi được khóa với đối tác dùng phần mềm khác.
- **A và B, tính bí mật** — bản mã giải được đúng từng byte theo cả hai chiều. Đây là yêu cầu tối thiểu của liên thông.
- **A và B, tính xác thực** — chữ ký số được xác minh đúng theo cả hai chiều, nên người nhận biết được thư đúng là do ai gửi.
- **C, chữ ký tách rời** — phục vụ trường hợp cần ký một tệp mà không thay đổi nội dung tệp đó.
- **D, tính toàn vẹn** — phép thử này chứng minh một **thuộc tính an toàn tiêu cực**: hệ thống từ chối dữ liệu đã bị sửa thay vì âm thầm cho ra bản rõ sai. Với hệ thống

mật mã, thất bại đúng cách quan trọng ngang thành công đúng cách: một hệ thống trả về bản rõ sai mà không báo lỗi còn nguy hiểm hơn một hệ thống không hoạt động.

B. ĐO HIỆU NĂNG

Lệnh chạy lại:

```
cd mailvelope
node scripts/benchmark-crypto.mjs
```

Mỗi giá trị là **trung vị** của nhiều lần chạy, để một lần chạy bất thường không làm lệch kết quả. Kịch bản kiểm tra tính đúng đắn sau mỗi vòng (độ dài dữ liệu sau khi giải mã phải khớp, chữ ký phải xác minh được) nên số liệu không thể đến từ một phép tính bị bỏ dờ.

B.1. Sinh cặp khóa

Bảng B.1. Thời gian sinh cặp khóa (thư viện thuần, một luồng)

Loại khóa	Trung vị	Các lần đo	Số lần chạy
RSA-2048	428 ms	564 / 428 / 362 ms	3
RSA-4096 (mặc định của sản phẩm)	2.785 ms	3.153 / 1.708 / 2.785 ms	3
ECC Curve25519	306 ms	348 / 254 / 306 / 318 / 247 ms	5

Độ tán mạn lớn của RSA là bình thường: thuật toán phải thử ngẫu nhiên cho tới khi tìm được số nguyên tố đủ lớn, nên thời gian phụ thuộc may rủi.

Đo bổ sung trên chính giao diện của bản phát hành, bằng kịch bản `scripts/capture-workflow.mjs` chạy trong trình duyệt thật:

Bảng B.2. Thời gian sinh khóa RSA-4096 qua giao diện thật, đo từ lúc bấm nút

Lần	Thời gian
Cặp khóa thứ nhất	10.237 ms (10,2 giây)
Cặp khóa thứ hai	8.116 ms (8,1 giây)

Con số này lớn hơn phép đo thư viện thuần vì bao gồm cả dựng giao diện, truyền tin giữa các thành phần của tiện ích và ghi vào kho lưu trữ. Đây là **thời gian người dùng thực sự chờ**, và là thao tác chỉ thực hiện **một lần** khi thiết lập ban đầu.

B.2. Mã hóa và giải mã

Mọi phép đo đều **mã hóa kèm ký số** và **giải mã kèm xác minh chữ ký** — đúng cấu hình mặc định của sản phẩm, không phải chỉ mã hóa đơn thuần.

Bảng B.3. Thời gian xử lý và độ giãn nở bản mã

Dữ liệu	Mã hóa + ký	Giải mã + xác minh	Kích thước bản mã	Độ giãn nở	Số lần chạy
Thư tiếng Việt tiêu biểu (~5 KB)	36,3 ms	19,4 ms	~9,3 KB	+87,8%	7
1 KB	14,9 ms	19,2 ms	3,0 KB	+197,1%	7
10 KB	16,3 ms	14,7 ms	15,5 KB	+51,8%	7
100 KB	34,0 ms	46,9 ms	141 KB	+37,2%	5
1 MB	115,1 ms	25,9 ms	1,36 MB	+35,7%	5
5 MB	403,5 ms	86,7 ms	6,78 MB	+35,6%	3

B.2.1. Cách đọc bảng này

Về độ trễ. Với thư điện tử thông thường, độ trễ do mã hóa nằm trong khoảng **15–36 mili giây** — dưới ngưỡng người dùng cảm nhận được (khoảng 100 ms). Người dùng không thấy sản phẩm chậm đi. Với tệp đính kèm 5 MB, tổng thời gian dưới nửa giây.

Về độ giãn nở. Bản mã lớn hơn bản rõ khoảng **36%** với dữ liệu lớn. Nguyên nhân chính là mã hóa ASCII-armor (Base64), tự nó đã làm tăng 33%, cần thiết để khối bản mã đi qua được hệ thống thư điện tử vốn chỉ bảo đảm truyền văn bản. Với dữ liệu nhỏ, tỷ lệ cao hơn vì phần tiêu đề cố định (khóa phiên được bọc bằng RSA-4096 cho mỗi người nhận, khối chữ ký) chiếm tỷ trọng lớn — nhưng giá trị tuyệt đối vẫn nhỏ.

Vì sao đây là trường hợp xấu nhất. Các phép đo theo kích thước dùng **dữ liệu ngẫu nhiên không nén được**. OpenPGP nén dữ liệu trước khi mã hóa; văn bản thật nén được đáng kể, nên độ giãn nở thực tế với thư văn bản thấp hơn con số trong bảng.

Dùng dữ liệu ngẫu nhiên là lựa chọn có chủ đích: số liệu phản ánh giới hạn trên chứ không phải một kết quả đẹp nhờ tính chất của dữ liệu thử.

Hệ quả thực tế cần lưu ý khi triển khai. Hạn mức một bức thư của Gmail là 25 MB. Với độ giãn nở ~36%, tệp đính kèm gốc lớn nhất gửi được là khoảng **18 MB**. Cần đưa điều này vào hướng dẫn người dùng.

Vì sao giải mã đôi khi nhanh hơn mã hóa. Với dữ liệu lớn, mã hóa phải nén, sinh khóa phiên, bọc khóa phiên bằng RSA cho từng người nhận và tạo chữ ký; giải mã chỉ mở một khóa phiên rồi giải mã đối xứng. Chênh lệch là hợp lý, không phải dấu hiệu bất thường.

C. HÌNH ẢNH GIAO DIỆN

Mọi ảnh chụp trong hồ sơ đều được sinh bằng kịch bản nạp **chính gói phát hành** vào trình duyệt Chrome ở chế độ không giao diện, rồi chụp lại. Không có ảnh nào là bản dựng minh họa hay ảnh chỉnh sửa.

Lệnh chạy lại:

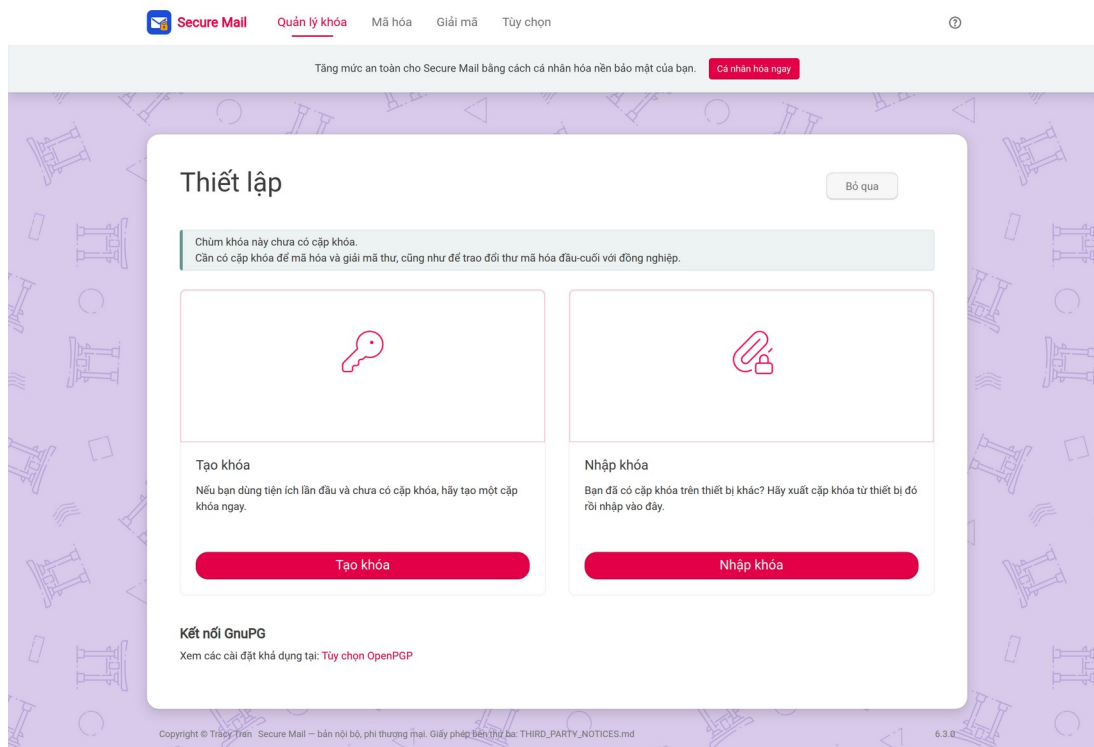
```
cd mailvelope
node scripts/capture-screenshots.mjs # các màn hình tĩnh, tiếng Anh và tiếng Việt
node scripts/capture-workflow.mjs # quy trình đầy đủ: sinh khóa thật rồi chụp
```

Kịch bản thứ hai thực hiện trọn quy trình: sinh hai cặp khóa RSA-4096 thật qua giao diện, mở màn hình chùm khóa, mở màn hình mã hóa và giải mã, đo thời gian từng bước. Vì vậy ảnh chụp chùm khóa cho thấy **khóa thật**, không phải dữ liệu dựng sẵn.

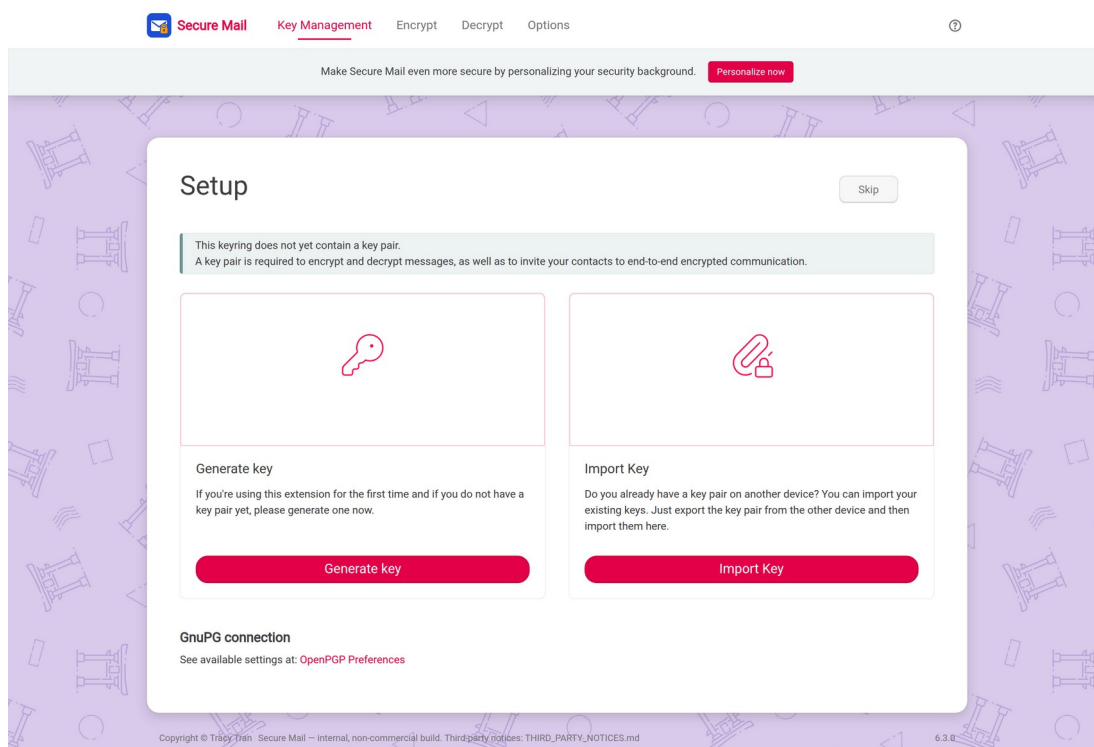
Bảng C.1. Danh mục ảnh chụp kèm theo hồ sơ

Tệp	Nội dung
settings-general.{en,vi}.png	Trang Tùy chọn → Chung, có bộ chọn ngôn ngữ
settings-keyserver.{en,vi}.png	Thư mục khóa — bốn cơ chế tra cứu bên ngoài ở trạng thái tắt
settings-security.{en,vi}.png	Tùy chọn bảo mật
settings-provider.{en,vi}.png	Cấu hình Gmail API
settings-watchlist.{en,vi}.png	Danh sách tên miền được phép
onboarding.{en,vi}.png	Màn hình thiết lập ban đầu

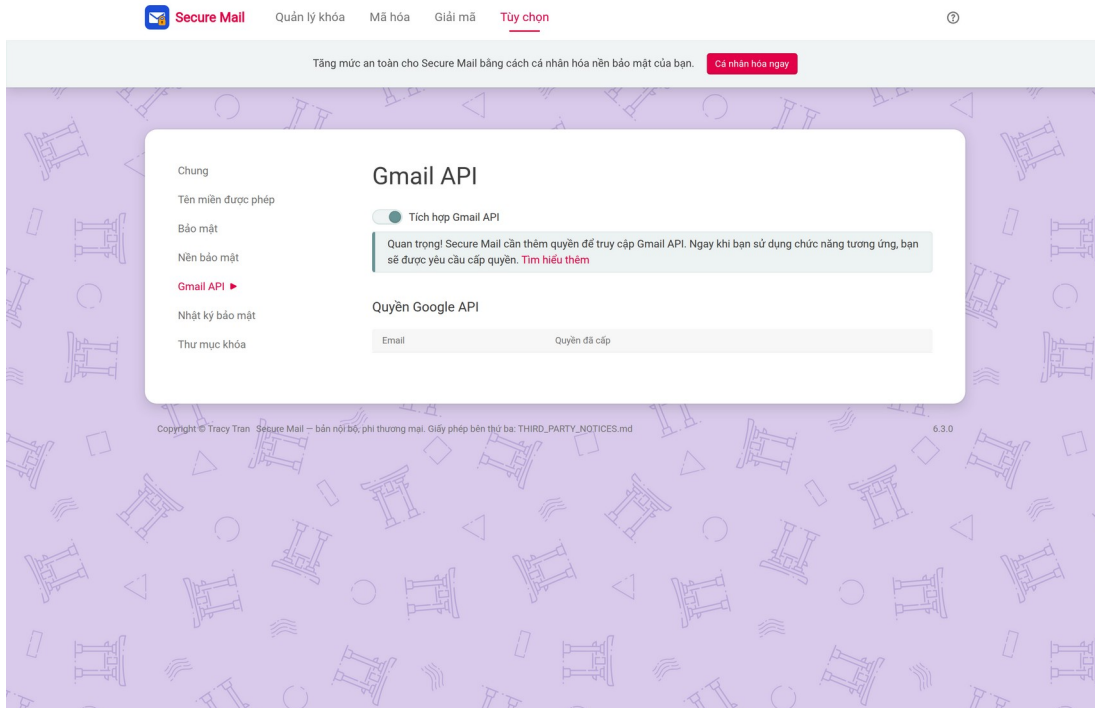
key-generate.{en,vi}.png	Màn hình tạo khóa
keyring-display.{en,vi}.png	Màn hình quản lý khóa
wf-01...wf-09	Chín ảnh của quy trình đầy đủ với khóa thật



Hình C.1. Màn hình thiết lập ban đầu bằng tiếng Việt, có nêu nguyên tắc quản trị viên chỉ giữ khóa công khai



Hình C.2. Cùng màn hình đó khi người dùng chọn tiếng Anh — cùng một bản cài đặt, chỉ khác lựa chọn ngôn ngữ



Hình C.3. Cấu hình Gmail API. Bản gốc hiển thị thêm bảng giấy phép thương mại cho tài khoản Workspace; bảng đó đã được gỡ bỏ

D. HƯỚNG DẪN TÁI LẬP TOÀN BỘ

Trình tự dưới đây dựng lại sản phẩm từ mã nguồn và chạy lại mọi phép kiểm chứng.

```
# 1. Chuẩn bị (Node.js >= 24 để biên dịch)
cd mailvelope
npm ci

# 2. Tạo tệp bí mật OAuth cục bộ (không nằm trong kho mã nguồn)
cp src/modules/oauth.local.example.js src/modules/oauth.local.js
# rồi điền client secret của dự án Google Cloud của đơn vị

# 3. Biên dịch grunt bản phát hành
npx grunt prod

# 4. Chạy toàn bộ kiểm thử và kiểm toán
npx jest --selectProjects unit # 449 phép thử
node scripts/verify-translation.mjs # kiểm toán bản dịch
./scripts/verify-no-external-endpoints.sh build/chrome
node scripts/interop-gnupg.mjs # cần cài GnuPG
node scripts/benchmark-crypto.mjs # đo hiệu năng
```

```
# 5. Chụp lại ảnh giao diện (cần Chrome for Testing)
npx puppeteer browsers install chrome
node scripts/capture-screenshots.mjs
node scripts/capture-workflow.mjs

# 5b. Dừng lại thiết kế giao diện Android
cd ../docs-sangkien/tools/mobile-ui
node capture.mjs && python3 compose.py

# 6. Kiểm thử bản di động
cd ../mobile
npm ci
npx jest # 68 phép thử
./scripts/verify-desktop-untouched.sh

# 7. Dừng lại toàn bộ hình vẽ và tài liệu của hồ sơ
cd ../docs-sangkien/tools
python3 make_diagrams.py # .drawio + .svg
+ .png
python3 build_docx.py ../02-THUYET-MINH-SANG-KIEN.md \
../02-THUYET-MINH-SANG-KIEN.docx ..
```

Lưu ý về việc nạp tiện ích để chụp ảnh. Bản Google Chrome thương mại từ chối tham số `--load-extension` (báo *"not allowed in Google Chrome, ignoring"*). Phải dùng bản **Chrome for Testing**, cài bằng `npx puppeteer browsers install chrome`. Kịch bản chụp ảnh đã ghi rõ điều này trong phần chú thích.

E. TỰ KIỂM CHỨNG SỐ LIỆU CỦA CHÍNH HỒ SƠ

Một hồ sơ yêu cầu Hội đồng tin vào các con số của nó thì phải chứng minh được các con số đó khi được hỏi. Vì vậy hồ sơ này đi kèm một kịch bản **tự kiểm tra chính mình**: nó đọc lại từng con số nêu trong tài liệu, tính lại đại lượng tương ứng từ kho mã nguồn, từ gói phát hành hoặc từ tệp kết quả đo, rồi báo sai nếu hai bên không khớp.

Lệnh chạy lại:

```
cd docs-sangkien
python3 tools/verify_claims.py # đối chiếu 33 số liệu
python3 tools/check_consistency.py # đánh số và tham chiếu chéo
```

Kết quả:

```
33 phép kiểm tra, 33 đạt, 0 sai
Không phát hiện vấn đề về đánh số và tham chiếu.
```

Kịch bản thứ nhất đối chiếu: số mục dịch, độ phủ bản dịch, số ngôn ngữ, số dòng danh mục ngôn ngữ, kết quả hai bộ kiểm thử, kết quả liên thông và phiên bản GnuPG dùng đối chứng, kết quả kiểm toán bề mặt mạng, sự vắng mặt của từng điểm cuối đã

gỡ trong gói phát hành, phiên bản thư viện mật mã, việc gói phụ thuộc đo lường đã bị gỡ, năm mốc thời gian mã hóa, hai lần đo sinh khóa trên giao diện thật, mã định danh tiện ích, mã băm gói phát hành, số tệp trong gói, số dòng các kịch bản, số tệp dự án di động, số tài liệu vận hành, số tệp biểu tượng, sự tồn tại của mọi hình được viện dẫn, và việc mỗi sơ đồ có đủ ba định dạng.

Kịch bản thứ hai kiểm tra bảng và hình được đánh số liên tiếp, mọi tham chiếu "Bảng N", "Hình N", "mục N" đều trở tới một mục có thật, kể cả tham chiếu chéo từ Bản thuyết minh sang Phụ lục này.

Toàn văn kết quả: `assets/measurements/claims-audit.txt` và `assets/measurements/consistency-audit.txt`.

Vì sao đưa việc này vào hồ sơ. Một tài liệu dài, nhiều số liệu, qua nhiều lần sửa thì gần như chắc chắn có chỗ lệch: một bảng được cập nhật mà đoạn văn nhắc tới nó thì không, một hình được đánh số lại mà tham chiếu thì quên. Những lỗi đó nhỏ nhưng làm hỏng lòng tin vào toàn bộ phần còn lại. Cách xử lý ở đây giống hệt cách xử lý các khẳng định về an toàn trong sản phẩm: **biến việc kiểm tra thành một lệnh chạy được, thay vì dựa vào việc đọc kỹ.**

F. DANH MỤC CHỨC NĂNG ĐẦY ĐỦ

Bản thuyết minh nêu bảng tổng hợp (51 chức năng, 5 nhóm). Phụ lục này liệt kê chi tiết từng chức năng, để Hội đồng thấy đầy đủ phạm vi sản phẩm bàn giao.

Cột "Nguồn gốc": **LK** = linh kiện sẵn có, giữ nguyên; **TK** = tác giả thiết kế lại; **XM** = tác giả xây dựng mới.

Bảng F.1. Nhóm quản lý khóa (14 chức năng)

Chức năng	Mô tả	Nguồn gốc
Tạo cặp khóa	RSA-2048/4096 hoặc ECC; đặt cụm mật khẩu, hạn dùng; sinh hoàn toàn trên máy người dùng	LK
Nhập khóa	Từ tệp hoặc dán khối văn bản; nhận cả khóa công khai và khóa riêng tư	LK
Xuất khóa	Xuất khóa công khai để nộp cho quản trị viên; xuất khóa riêng tư để sao lưu	LK

Xóa khóa	Gỡ khóa khỏi chùm khóa	LK
Đặt khóa mặc định	Khóa dùng để ký và tự thêm vào danh sách người nhận	LK
Xem chi tiết khóa	Định danh, dấu vân tay, thuật toán, độ dài, ngày tạo, hạn dùng, khóa phụ, trạng thái	LK
Đổi cụm mật khẩu khóa	Đổi mật khẩu bảo vệ khóa riêng tư mà không đổi khóa	LK
Sửa hạn dùng khóa	Gia hạn hoặc đặt lại thời hạn	LK
Thu hồi khóa	Phát hành chứng chỉ thu hồi khi khóa bị lộ hoặc hết vai trò	LK
Thêm định danh người dùng	Nhiều địa chỉ email trên cùng một khóa	LK
Thu hồi định danh người dùng	Gỡ một địa chỉ khỏi khóa	LK
Kiểm tra cụm mật khẩu	Xác nhận người dùng còn nhớ mật khẩu khóa	LK
Tra khóa từ thư mục bên ngoài	Bốn cơ chế (máy chủ khóa, WKD, Autocrypt) — chuyển sang tắt mặc định	TK
Quy trình phân phối khóa nội bộ	Danh mục khóa công khai do quản trị viên phát hành, kèm mẫu CSV và tài liệu quy trình	XM

Bảng F.2. Nhóm mã hóa và giải mã (9 chức năng)

Chức năng	Mô tả	Nguồn gốc
Mã hóa thư	Khóa phiên AES-256, bọc bằng khóa công khai của từng người nhận	LK
Giải mã thư	Mở khóa riêng tư, khôi phục khóa phiên, kiểm tra toàn vẹn	LK
Ký số	Ký bằng khóa riêng tư người gửi; mặc định bật	LK
Xác minh chữ ký	Hiển thị rõ ba trạng thái: hợp lệ, không hợp lệ, không có chữ ký	LK
Mã hóa tệp đính kèm	Xử lý tệp nhị phân, tối đa ~18 MB sau khi giãn nở (hạn mức Gmail)	LK
Giải mã tệp đính kèm	Kèm kiểm tra toàn vẹn	LK
Chữ ký tách rời	Ký một tệp mà không thay đổi nội dung tệp	LK
Cảnh báo khóa hết hạn hoặc bị thu hồi	Chặn việc vô tình gửi cho một khóa không còn hợp lệ	LK
Chuỗi phiên bản trên khối bản	Đổi sang nhận diện của sản	TK

mã	phẩm	
----	------	--

Bảng F.3. Nhóm tích hợp thư điện tử (9 chức năng)

Chức năng	Mô tả	Nguồn gốc
Tích hợp Gmail qua giao diện web	Chèn nút mã hóa, khung soạn thảo cách ly, khung đọc cách ly	LK
Tích hợp Gmail qua API	Đọc và gửi thư mã hóa trực tiếp qua Gmail API	LK
Hỗ trợ 14 nhà cung cấp webmail khác	Outlook, Yahoo, Zoho, mailbox.org, Posteo, GMX, WEB.DE, mail.ru...	LK
Danh sách tên miền được phép	Quản trị viên thêm hoặc bớt trang web được phép tích hợp	LK
Giao diện lập trình cho trang web	Ứng dụng web gọi được chức năng mã hóa của tiện ích	LK
Xác thực OAuth 2.0 với Gmail	Bổ sung PKCE S256 và định danh tiện ích cố định	TK
Chọn tài khoản khi đăng nhập	Sửa lỗi tự động dùng tài khoản đang đăng nhập trong trình duyệt	TK
Hỗ trợ tài khoản Google Workspace	Gỡ cơ chế kiểm tra giấy phép thương mại vốn chặn loại tài khoản này	TK
Biểu mẫu mã hóa	Trang web thu thập dữ liệu đã mã hóa sẵn phía người dùng	TK

Bảng F.4. Nhóm an toàn và vận hành (13 chức năng)

Chức năng	Mô tả	Nguồn gốc
Sao lưu khóa riêng tư	Tập sao lưu được mã hóa bằng cụm mật khẩu riêng	LK
Khôi phục từ bản sao lưu	Đưa khóa trở lại trên thiết bị mới	LK
Phiếu khôi phục	Bản in giấy chứa mã khôi phục, cất giữ ngoài máy tính	LK
Bộ nhớ đệm cụm mật khẩu	Bật mặc định, tự xóa sau 30 phút không sử dụng	LK
Nền bảo mật chống giả mạo	Hoa văn nền do người dùng cá nhân hóa, giúp nhận ra hộp thoại giả	LK
Nhật ký bảo mật	Ghi lại các thao tác mật mã đã thực hiện trên máy	LK
Ấn tiêu đề khối bản mã	Tùy chọn không để lộ phiên bản phần mềm trong bản mã	LK

Hỗ trợ GnuPG cục bộ	Dùng chùm khóa GnuPG của hệ điều hành	LK
Đo lường từ xa	Đã gỡ bỏ hoàn toàn khỏi mã nguồn	TK
Kiểm toán bề mặt mạng	Kịch bản kiểm tra gói phát hành không chứa điểm cuối đã gỡ	XM
Kiểm chứng liên thông	Kịch bản trao đổi thư hai chiều với GnuPG	XM
Đo hiệu năng	Kịch bản đo thời gian sinh khóa, mã hóa, giải mã, độ giãn nở	XM
Niêm phong bản phát hành	Mã băm SHA-256 cho gói cài đặt và cho từng tệp	XM

Bảng F.5. Nhóm giao diện và ngôn ngữ (6 chức năng)

Chức năng	Mô tả	Nguồn gốc
Giao diện tiếng Việt	586/586 chuỗi, độ phủ 100%, thuật ngữ chuẩn hóa	XM
Bộ chọn ngôn ngữ trong ứng dụng	Theo trình duyệt / English / Tiếng Việt	XM
Kiểm toán chất lượng bản dịch	Kịch bản kiểm tra độ phủ, ô thay thế, thẻ đánh dấu, nhất quán thuật ngữ	XM
Cảnh báo an toàn trong giao diện	Ba nguyên tắc cốt lõi hiển thị tại màn hình thiết lập, bằng tiếng Việt	XM
14 ngôn ngữ kế thừa	Vẫn hoạt động qua cơ chế đa ngữ của trình duyệt	LK
Nhận diện sản phẩm	Biểu tượng, tên, màu sắc riêng ở toàn bộ điểm hiển thị	TK

G. MA TRẬN KIỂM THỬ ỨNG DỤNG ANDROID

Phần nền tảng của bản di động đã được kiểm thử tự động (68/68 đạt, mục A.3). Phần **giao diện chạy trên thiết bị Android thật** là công việc của giai đoạn 2. Ma trận dưới đây được lập sẵn để việc kiểm thử đó có căn cứ và có thể bàn giao cho người khác thực hiện.

Cách dùng bảng. Cột *Trạng thái* hiện ghi CHỜ cho mọi phép thử chưa thực hiện trên thiết bị. Sau khi chạy, người kiểm thử điền ĐẠT hoặc KHÔNG ĐẠT kèm ghi chú. Hồ

sơ **không ghi sẵn kết quả cho phép thử chưa chạy**: một bảng kết quả không có thật sẽ phá vỡ chính nguyên tắc kiểm chứng được mà toàn bộ sáng kiến dựa trên đó.

Thiết bị đề xuất: tối thiểu hai máy — một máy Android 10–12 và một máy Android 13 trở lên — để phủ được khác biệt về Android Keystore và về quyền truy cập tệp.

Bảng G.1. Ma trận kiểm thử chức năng trên thiết bị Android

Mã	Phép thử	Tiêu chí đạt	Trạng thái
A-01	Cài đặt và khởi chạy lần đầu	Ứng dụng khởi chạy, hiển thị màn hình thiết lập bằng tiếng Việt	CHỜ
A-02	Đặt cụm mật khẩu thiết bị	Chấp nhận cụm mật khẩu hợp lệ, từ chối cụm quá ngắn	CHỜ
A-03	Sinh cặp khóa RSA-4096	Hoàn tất, khóa xuất hiện trong chùm khóa; ghi lại thời gian thực tế	CHỜ
A-04	Hiển thị dấu vân tay khóa	Dấu vân tay khớp với giá trị hiển thị trên bản máy tính cho cùng một khóa	CHỜ
A-05	Nhập khóa công khai từ tệp	Khóa được nhập, hiển thị nhãn "chưa đối chiếu vân tay"	CHỜ
A-06	Đánh dấu đã đối chiếu vân tay	Nhãn chuyển sang trạng thái đã xác nhận	CHỜ
A-07	Mã hóa thư cho một người nhận	Sinh khối bản mã hợp lệ	CHỜ
A-08	Mã hóa thư cho nhiều người nhận	Mọi người nhận đều giải mã được	CHỜ
A-09	Ký thư khi gửi	Người nhận xác minh được chữ ký	CHỜ
A-10	Giải mã thư nhận được	Bản rõ đúng, tiếng Việt có dấu nguyên vẹn	CHỜ
A-11	Hiển thị trạng thái chữ ký hợp lệ	Hiển thị đúng tên và địa chỉ người ký	CHỜ
A-12	Hiển thị trạng thái chữ ký không hợp lệ	Cảnh báo rõ ràng, không hiển thị như thư hợp lệ	CHỜ
A-13	Mã hóa và giải mã tệp đính kèm	Tệp khôi phục đúng từng byte	CHỜ
A-14	Sao lưu khóa riêng tư	Tạo được tệp sao lưu,	CHỜ

		mã hóa bằng cụm mật khẩu riêng	
A-15	Khôi phục trên thiết bị thứ hai	Khóa hoạt động, giải mã được thư cũ	CHỜ
A-16	Xuất khóa công khai và chia sẻ	Chia sẻ được qua trình chia sẻ của Android	CHỜ

Bảng G.2. Ma trận kiểm thử an toàn trên thiết bị

Mã	Phép thử	Tiêu chí đạt	Trạng thái
S-01	Khóa ứng dụng khi chuyển sang ứng dụng khác	Yêu cầu mở khóa lại khi quay lại	CHỜ
S-02	Mở khóa bằng vân tay	Hoạt động; khi vân tay không khớp thì lùi về cụm mật khẩu	CHỜ
S-03	Tự xóa bộ nhớ đệm cụm mật khẩu	Sau thời gian cấu hình, yêu cầu nhập lại	CHỜ
S-04	Chặn chụp màn hình	Nội dung bị ẩn trong danh sách ứng dụng gần đây	CHỜ
S-05	Khóa riêng tư trong kho dữ liệu	Tệp trên máy không đọc được bằng công cụ duyệt tệp	CHỜ
S-06	Hộp thoại cụm mật khẩu là thành phần gốc	Không phải nội dung web trong WebView	CHỜ
S-07	Ứng dụng không phát sinh kết nối ngoài dự kiến	Bắt gói tin: không có kết nối nào ngoài Gmail API	CHỜ
S-08	Từ chối bản mã bị sửa	Sửa một ký tự → báo lỗi, không trả về bản rõ sai	CHỜ

Bảng G.3. Ma trận kiểm thử liên thông giữa các nền tảng

Mã	Phép thử	Tiêu chí đạt	Trạng thái
L-01	Android mã hóa → bản máy tính giải mã	Bản rõ đúng, chữ ký hợp lệ	CHỜ
L-02	Bản máy tính mã hóa → Android giải mã	Bản rõ đúng, chữ ký hợp lệ	CHỜ
L-03	Android mã hóa → GnuPG giải mã	Bản rõ đúng, GnuPG báo chữ ký hợp lệ	CHỜ
L-04	GnuPG mã hóa → Android giải mã	Bản rõ đúng, chữ ký xác minh được	CHỜ

L-05	Khóa sinh trên Android dùng được trên máy tính	Nhập và dùng bình thường	CHỜ
L-06	Bản sao lưu từ máy tính khôi phục được trên Android	Khóa hoạt động sau khôi phục	CHỜ

Bảng G.4. Ma trận kiểm thử hiệu năng và tương thích

Mã	Phép thử	Chỉ tiêu tham chiếu	Trạng thái
P-01	Thời gian sinh khóa RSA-4096 trên thiết bị	So với 8–10 giây đo trên máy tính	CHỜ
P-02	Thời gian mã hóa một bức thư ~5 KB	So với 36 ms đo trên máy tính	CHỜ
P-03	Thời gian giải mã một bức thư ~5 KB	So với 19 ms đo trên máy tính	CHỜ
P-04	Mã hóa tệp đính kèm 5 MB	Ghi lại thời gian và mức tiêu thụ bộ nhớ	CHỜ
P-05	Hoạt động trên Android 10–12	Không lỗi ở Keystore và quyền truy cập tệp	CHỜ
P-06	Hoạt động trên Android 13 trở lên	Không lỗi ở quyền thông báo và quyền tệp	CHỜ
P-07	Hoạt động khi xoay màn hình	Không mất dữ liệu đang nhập	CHỜ
P-08	Hoạt động khi hết bộ nhớ và bị hệ điều hành thu hồi	Khôi phục đúng trạng thái, yêu cầu mở khóa lại	CHỜ

Tổng cộng 38 phép thử. Sau khi thực hiện, kết quả được tổng hợp bổ sung vào mục này và vào Bảng *Kết quả các bộ kiểm thử tự động* của Bản thuyết minh.

H. TẬP DỮ LIỆU KÈM THEO

Bảng H.1. Tập kết quả gốc kèm theo hồ sơ

Tập	Nội dung
assets/measurements/crypto-benchmark.json	Toàn bộ số liệu hiệu năng, kèm cấu hình máy đo và từng lần đo
assets/measurements/interop-gnupg.json	Kết quả 8 phép thử liên thông, dạng máy đọc được
assets/measurements/translation-audit.json	Báo cáo kiểm toán bản dịch, kèm chi tiết từng nhóm lỗi
assets/measurements/workflow-	Thời gian đo trên giao diện thật

timings.json	
assets/measurements/network-audit.txt	Toàn văn kết quả kiểm toán bề mặt mạng
assets/measurements/interop-gnupg.txt	Toàn văn nhật ký phép thử liên thông
assets/measurements/translation-audit.txt	Toàn văn kết quả kiểm toán bản dịch
assets/measurements/desktop-tests.txt	Kết quả kiểm thử bản máy tính
assets/measurements/mobile-tests.txt	Kết quả kiểm thử bản di động
assets/measurements/webview-chromium.json	Kết quả chạy lỗi mật mã trong Chromium
assets/measurements/claims-audit.txt	Kết quả tự kiểm chứng 33 số liệu của hồ sơ
assets/measurements/consistency-audit.txt	Kết quả kiểm tra đánh số và tham chiếu chéo
assets/diagrams/*.drawio	Sơ đồ nguồn, mở và sửa được bằng diagrams.net
assets/diagrams/*.svg	Sơ đồ dạng vector
assets/diagrams/*.png	Sơ đồ dạng ảnh, dùng để nhúng vào tài liệu
assets/screenshots/*.png	Ảnh chụp giao diện của bản máy tính
assets/mobile-design/*.png	12 thiết kế màn hình ứng dụng Android và 2 bản ghép trình bày
tools/mobile-ui/	Mã nguồn thiết kế giao diện Android và kịch bản dựng lại ảnh

Mỗi sơ đồ có đủ **ba định dạng từ cùng một nguồn định nghĩa** (tools/make_diagrams.py), nên tệp sửa được và ảnh xuất bản không bao giờ lệch nhau. Nếu cần chỉnh sửa một hình, mở tệp .drawio tương ứng bằng diagrams.net.